Microsoft 365 Email Authentication — SPF, DKIM & DMARC

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary 4

Solution Overview 4

What this is . . . 4

How it works — the Exchange Online model . . . 5

Reference model — the monitor→enforce journey . . . 6

Benefits . . . 6

Limitations & constraints . . . 6

Deployment model . . . 7

Requirements 7

R1. A complete inventory of legitimate senders for each domain . . . 7

R2. Accepted domains configured and verified in Exchange Online . . . 7

R3. Note the tenant initial (onmicrosoft) domain and Domain GUID . . . 8

R4. DNS zone access with support for TXT and CNAME (and DMARC subdomain records) . . . 8

R5. DKIM signing keys / alignment method from each third-party sender . . . 9

R6. A DMARC aggregate-report (RUA) destination . . . 9

R7. Exchange Administrator role and (hybrid) on-prem transport insight . . . 9

Global Requirements — Microsoft 365 / Exchange Messaging Solutions 10

1. Microsoft 365 tenant with Exchange Online . . . 10

2. Administrative access (least-privilege Exchange/365 roles) . . . 11

3. Exchange Online PowerShell (EXO V3) + Graph toolchain . . . 11

4. DNS control for the mail domains . . . 11

5. Hybrid Exchange & Active Directory (for hybrid solutions) . . . 12

6. A pilot scope and change control . . . 12

Implementation 12

Phase 1 — Assess (inventory & baseline) . . . 13

Phase 2 — Design . . . 14

Phase 3 — Configure (publish SPF & DKIM, DMARC at monitor) . . . 14

Phase 4 — Pilot (monitor with aggregate reports) . . . 16

Phase 5 — Validate . . . 16

Phase 6 — Expand (roll DMARC to enforcement) . . . 16

Testing & Validation 17

T1. SPF resolves as a single, scoped record . . . 17

T2. DKIM signing is enabled and valid . . . 17

T3. A test message passes SPF and DKIM (and aligns) . . . 17

T4. DMARC record is published and reports arrive . . . 18

T5. All legitimate senders pass DMARC with alignment (enforcement gate) . . . 18
T6. Alignment validation report is green . . . 18
T7. Enforcement takes effect without dropping legitimate mail . . . 18
T8. DKIM rotation succeeds . . . 19
Troubleshooting 19
SPF . . . 19
DKIM . . . 19
DMARC . . . 20
Environment / cloud . . . 21
Best Practices 22
Sequence and evidence . . . 22
SPF hygiene . . . 22
DKIM hygiene . . . 22
DMARC hygiene . . . 22
Operations . . . 23
Government / sovereign cloud . . . 23
Deliverables Summary 23
Documentation . . . 23
PowerShell scripts (Exchange Online PowerShell / Microsoft Graph) . . . 24
Packaged artifacts . . . 24
Appendix A — PowerShell Scripts 26

Executive Summary

Outcome. This solution makes a Microsoft 365 email domain **impossible to spoof and reliably deliverable**. It implements the three standards that together authenticate outbound mail — **SPF**, **DKIM**, and **DMARC** — and then advances DMARC to full **enforcement (**`p=reject`**)** so that any message forging the organization's domain is quarantined or rejected by receiving mail systems, while legitimate mail authenticates cleanly and lands in the inbox.

The problem it solves. A domain without enforced authentication can be spoofed by attackers to send convincing phishing and business-email-compromise messages *as* the organization, and its own legitimate mail is more likely to be filtered as spam. Publishing the records is easy; doing it **without breaking legitimate mail** — across Exchange Online, hybrid/on-premises servers, and dozens of third-party senders (marketing, CRM, ticketing, billing, scanners) — is where most efforts stall or cause an outage.

Approach — why it is low-risk. The work follows a disciplined, evidence-based path: **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand**. Every legitimate sender is inventoried first; SPF is scoped to stay within the hard 10-lookup limit; Exchange Online DKIM signing is enabled with Microsoft-managed keys; and DMARC is published in **monitoring mode (**`p=none`**)** so that **aggregate reports** reveal exactly which systems send as the domain before any enforcement. Enforcement is only switched on — and then ramped `none` → `quarantine` → `reject` — once the reports prove that 100% of legitimate mail passes and aligns. Every change is a single DNS/authentication record with an immediate rollback (step the policy back one stage), so production mail flow is never exposed to guesswork.

What's included. A complete implementation guide (inventory, SPF, DKIM, DMARC rollout with pass/fail gates and rollback), a requirements guide, testing and validation procedures, best practices for reaching `p=reject` safely, and **five PowerShell tools** (Exchange Online PowerShell / Microsoft Graph) for posture discovery, DKIM enable/rotate, DMARC aggregate-report analysis, alignment validation, and SPF/scope health — all **read-only or** `-WhatIf` **by default**, with no credentials stored in code.

Bottom line. A Microsoft 365 domain that can't be spoofed and stays in the inbox — SPF scoped, DKIM signing on, DMARC enforced on real report data, and third-party senders aligned — delivered through a self-guided, tested process at a fraction of bespoke consulting cost.

Solution Overview

What this is

This solution implements **email authentication** for a Microsoft 365 domain: it publishes and scopes **SPF**, enables **DKIM** signing in Exchange Online (and aligns on-premises/hybrid and third-party senders), and rolls **DMARC** from monitoring to enforcement (`p=none` → `p=quarantine` → `p=reject`) using real **aggregate report** data. The outcome is a domain that receivers can authenticate — so attackers can no longer spoof it and legitimate mail is far less likely to be filtered.

Email authentication is three cooperating DNS-based mechanisms plus the concept of **alignment**:

- **SPF (Sender Policy Framework)** — a DNS TXT record listing the hosts/services authorized to send

mail *for the envelope (MAIL FROM / Return-Path) domain*. Receivers check the connecting IP against the record. SPF authenticates the **envelope** domain, not the visible `From:` header.

- **DKIM (DomainKeys Identified Mail)** — a cryptographic signature added to the message header. The

receiver retrieves the public key from DNS (a selector record) and verifies the signature, proving the message was signed by the signing domain and was not altered in transit. In Exchange Online the public keys are published as **CNAME** records that point back to Microsoft-hosted keys, so key material and rotation are managed by the service.

- **DMARC (Domain-based Message Authentication, Reporting & Conformance)** — a DNS TXT record at

`_dmarc.<domain>` that (a) tells receivers what to do with mail that fails authentication (`p=none`, `quarantine`, or `reject`), and (b) requests **aggregate (RUA)** and optionally **forensic (RUF)** reports. DMARC only passes when SPF *or* DKIM passes **and** is **aligned** with the `From:` header domain.

- **Alignment** — DMARC's core requirement. **SPF alignment**: the SPF-authenticated MAIL FROM domain

matches the `From:` domain (relaxed alignment allows a shared organizational domain). **DKIM alignment**: the d= signing domain of a passing DKIM signature matches the `From:` domain. A message can pass raw SPF/DKIM yet still **fail DMARC** if neither result aligns with `From:` — which is exactly what breaks many third-party senders until they are configured correctly.

How it works — the Exchange Online model

For mail sent **from Exchange Online** for your accepted domain:

- **SPF:** Microsoft 365 mail leaves through Microsoft's outbound IPs, represented by the SPF include

`include:spf.protection.outlook.com`. You publish a single SPF TXT record per domain that includes that plus every other legitimate sender, ending in `-all` (hard fail) once the inventory is complete.

- **DKIM:** Exchange Online supports 2048-bit DKIM signing per accepted domain. You enable it and publish

two CNAME records — `selector1._domainkey` and `selector2._domainkey` — that point to `selector1-<domainGUID>._domainkey.<initialDomain>.onmicrosoft.com` (and `selector2-…`). Microsoft hosts the keys behind those CNAMEs and rotates between the two selectors; `Rotate-DkimSigningConfig` triggers a rotation. Until you enable custom-domain DKIM, Exchange Online still signs with the tenant's `onmicrosoft.com` domain, which does **not** align to your custom `From:` domain for DMARC.

- **DMARC:** You publish `_dmarc.<domain>` and use the aggregate reports to confirm all legitimate mail

authenticates and aligns **before** tightening the policy.

For **on-premises / hybrid** senders and **third-party** senders (marketing platforms, ticketing systems, ERP/CRM notifications, scanners/MFPs, help-desk tools), each source must be brought into alignment: added to SPF where it sends as your domain, DKIM-signed by that platform with your domain as d= (using keys the platform provides), or routed so that an aligned identifier is present. Sources that cannot be aligned are candidates to move behind Exchange Online or a subdomain, or to accept that they will fail DMARC (which is why you never enforce before reading the reports).

Reference model — the monitor→enforce journey

```
Assess      Inventory every legitimate sender for each domain (EXO, on-prem/hybrid, 3rd-party).
Design      Plan the SPF record (< 10 DNS lookups), DKIM selectors, and the DMARC rollout stages.
Configure   Publish/scope SPF; enable EXO DKIM (CNAMEs); publish DMARC at p=none with rua=.
Pilot       Collect aggregate reports (typically 2–4 weeks); confirm all legit sources pass+align.
Validate    Every source authenticates and aligns; no legitimate mail is failing DMARC.
Expand      Move DMARC p=none → p=quarantine (pct ramp) → p=reject; keep monitoring reports.
```

The DMARC policy is deliberately advanced in stages — `p=none` **(monitor)** → `p=quarantine` → `p=reject` — often with the `pct=` tag used to quarantine/reject only a percentage first. Each step is gated on the aggregate reports showing no legitimate mail failing, so enforcement never silently drops real business mail.

Benefits

- **Anti-spoofing:** at `p=reject`, receivers honoring DMARC reject mail that forges your `From:` domain, neutralizing direct-domain spoofing and much exact-domain phishing.
- **Deliverability:** authenticated, aligned mail is trusted by receivers and less likely to be junked; DMARC enforcement is a positive reputation signal.
- **Visibility:** aggregate reports reveal *every* IP/service sending as your domain — including shadow IT and abuse — which is valuable even before enforcement.
- **Evidence-based:** enforcement is driven by real report data, not guesswork, so the cutover is low risk.

Limitations & constraints

- **DMARC only covers the visible `From:` domain**, not display-name spoofing, look-alike/cousin domains, or compromised-account (already-authenticated) mail — those need anti-phishing controls (e.g. Defender for Office 365 anti-phish, spoof intelligence), which are complementary, not replaced.
- **SPF has a hard limit of 10 DNS lookups**; exceeding it yields a `permerror` and SPF fails. Nested `include:` chains from many third-party senders are the usual cause — this solution scopes and flattens/consolidates to stay under the limit.
- **Forwarding breaks SPF** (the forwarder's IP isn't in your record) and can break DKIM if the body is altered; DMARC survives forwarding only when a still-aligned DKIM signature remains — a reason to rely on DKIM alignment, not SPF alone.
- **Receiver-dependent:** DMARC is only enforced by receivers that implement it (most large mailbox providers do). It is not a guarantee against all abuse.
- **Version/plan/cloud dependencies:** exact anti-phish/spoof-intelligence features depend on **EOP vs Defender for Office 365 **plan;** Government (GCC/GCC High/DoD)** clouds use different portal URLs (e.g. `admin.exchange.office365.us`) and the tenant's initial domain is `*.onmicrosoft.us` — verify in your tenant/version/cloud.

Deployment model

This solution follows the house model — **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand** — pilot-first, with explicit pass/fail gates and a documented rollback at every DNS/authentication change. SPF, DKIM, and DMARC changes are **high-impact to production mail**: a mis-scoped SPF record or a premature `p=reject` can cause legitimate mail to be filtered or rejected. Every change here is staged, verified against aggregate-report evidence, and reversible.

Requirements

These are the **solution-specific** prerequisites for implementing SPF, DKIM, and DMARC on a Microsoft 365 domain. They build on the shared **Global Requirements — Microsoft 365 / Exchange Messaging Solutions** (`global-requirements-messaging.md`): a Microsoft 365 tenant with Exchange Online (GR-1), least-privilege admin access (GR-2), the EXO V3 / Graph toolchain (GR-3), DNS control for the mail domains (GR-4), on-prem Exchange/AD/AAD-Connect access for hybrid (GR-5), and a pilot scope + change control (GR-6). Verify those first, then confirm the additional items below.

R1. A complete inventory of legitimate senders for each domain

• **Description:** A documented list of **every** system that sends mail *as* each in-scope domain:

Exchange Online mailboxes, on-premises/hybrid Exchange, and third-party senders (marketing/ESP platforms, CRM/ERP notifications, ticketing/help-desk, monitoring/alerting, billing, scan-to-email MFPs/printers, application relay hosts).

• **Why required:** DMARC enforcement (`p=reject`) will cause any *un-inventoried* legitimate sender that

isn't aligned to be quarantined or rejected. You cannot safely scope SPF or reach enforcement without knowing every source. This is the single most important input to the whole rollout.

• **How to verify:** Cross-check the message-trace/aggregate-report data against the list. The provided

`Get-EmailAuthPosture` discovery script and, once DMARC monitoring is live, the aggregate-report parser (`Invoke-DmarcReportAnalysis`) surface every IP/service seen sending as your domain — reconcile those against the documented inventory until there are no unknowns.

• **How to implement if missing:** Build the inventory from message trace, procurement/vendor lists,

and (after publishing `p=none`) the DMARC aggregate reports over 2–4 weeks. Treat "unknown source in reports" as a gate that blocks enforcement.

R2. Accepted domains configured and verified in Exchange Online

• **Description:** Each in-scope sending domain is an **accepted domain** in Exchange Online and is a

verified custom domain in the Microsoft 365 admin center.

• **Why required:** DKIM signing is enabled **per accepted domain**; SPF and DMARC records are published

on the domain's DNS zone. An unverified/unconfigured domain cannot be DKIM-signed by Exchange Online.

- **How to verify:** `Get-AcceptedDomain` lists the domain; the M365 admin center **Settings > Domains**

shows it as *Healthy/Verified*.

- **How to implement if missing:** Add and verify the domain (M365 admin center **Settings > Domains >

Add domain**), then confirm it appears via `Get-AcceptedDomain`.

R3. Note the tenant initial (onmicrosoft) domain and Domain GUID

- **Description:** The tenant's initial domain (`<tenant>.onmicrosoft.com`, or `.onmicrosoft.us` in

Government clouds) and each custom domain's **Domain GUID**, which appear in the DKIM CNAME targets (`selector1-<domainGUID>._domainkey.<initialDomain>`).

- **Why required:** The two DKIM **CNAME** records you publish must point at the exact Microsoft-hosted

targets derived from the initial domain and Domain GUID. Getting these wrong is the most common cause of DKIM enable failing.

- **How to verify:** `Get-DkimSigningConfig -Identity <domain> | Format-List *CNAME*` returns the exact

`Selector1CNAME` / `Selector2CNAME` targets to publish (available after the config object exists).

- **How to implement if missing:** Retrieve the CNAME targets from `Get-DkimSigningConfig` (or the EAC

DKIM pane, which displays "Publish these two CNAME records") and hand them to whoever controls DNS.

R4. DNS zone access with support for TXT and CNAME (and DMARC subdomain records)

- **Description:** Beyond generic DNS control (GR-4), confirm the provider supports **TXT** records

(for SPF and DMARC), **CNAME** records at `selector1._domainkey` / `selector2._domainkey` (for DKIM), and a TXT record at the `_dmarc` subdomain (and, if used, `<sub>._domainkey` / `_dmarc.<sub>` for subdomains). Note the zone's TTLs.

- **Why required:** DKIM specifically requires CNAME support at the `_domainkey` labels; some DNS

editors mangle long TXT values or reject underscore labels. Low TTLs make staged DMARC changes and rollback faster.

- **How to verify:** Create a throwaway test TXT/CNAME and confirm it resolves (`nslookup -type=txt`,

`Resolve-DnsName`). The provided validation script performs live DNS lookups of each record.

- **How to implement if missing:** If the current provider can't host the required records (rare), move

the zone or use the provider's advanced-DNS mode; lower TTLs (e.g. 300–3600s) before starting the DMARC ramp.

R5. DKIM signing keys / alignment method from each third-party sender

- **Description:** For each third-party platform that sends as your domain, the vendor's method to make its mail **DMARC-aligned** — typically DKIM keys/selectors to publish as CNAMEs in your zone (so the platform signs with d=<yourdomain>), and/or the SPF `include:` to add. Some platforms use a dedicated sending subdomain.
- **Why required:** A third-party sender only passes DMARC for your domain when it produces an **aligned** SPF or DKIM result. Missing platform DKIM setup is the usual reason a legitimate marketing/CRM stream fails DMARC at enforcement.
- **How to verify:** After configuring, aggregate reports show that source passing DMARC with an aligned d= or aligned SPF; the validation script flags sources seen without alignment.
- **How to implement if missing:** From each vendor's documentation, enable domain authentication on their side and publish the CNAME/TXT records they provide. (Vendor consoles are deferred to the vendor's own docs — the pattern is: publish their keys, verify in their console, confirm alignment in the reports.)

R6. A DMARC aggregate-report (RUA) destination

- **Description:** A mailbox or DMARC-reporting endpoint to receive the aggregate (RUA) XML reports — either an internal mailbox you can parse or a hosted DMARC analytics service. If reporting to a domain other than the checked domain, that receiver must publish the `external destination verification` record (<yourdomain>._report._dmarc.<reportdomain> TXT = v=DMARC1).
- **Why required:** The entire monitor→enforce journey is driven by these reports; you cannot safely tighten policy without them.
- **How to verify:** Reports arrive at the RUA address within 24–72h of publishing p=none; the parser script (`Invoke-DmarcReportAnalysis`) ingests them.
- **How to implement if missing:** Provision a dedicated mailbox (e.g. `dmarc-reports@<domain>`) or a reporting service, and — for cross-domain reporting — publish the external-destination verification TXT record.

R7. Exchange Administrator role and (hybrid) on-prem transport insight

- **Description:** The **Exchange Administrator** role is sufficient for `Get/Set/New-DkimSigningConfig`, `Rotate-DkimSigningConfig`, and reading connectors/message trace. For **hybrid**, add read access to on-premises Exchange transport (send connectors, the outbound path/IP or smart host) so on-prem-origin

mail can be brought into SPF/DKIM alignment.

• **Why required:** DKIM cmdlets and mail-flow inspection require these roles; hybrid on-prem mail that egresses directly (not via Exchange Online) needs its own SPF entry and DKIM/alignment plan.

• **How to verify:** `Get-DkimSigningConfig` succeeds; you can enumerate on-prem send connectors and the outbound public IP(s).

• **How to implement if missing:** Have a Global Admin assign **Exchange Administrator**; obtain on-prem Exchange admin read access for the hybrid transport review.

> ***Government cloud note (per the house Commercial-vs-Government rule).*** *In* ***GCC High / DoD****, the initial domain is* `*.onmicrosoft.us`*, admin portals are on* `*.office365.us` *(e.g.* `admin.exchange.office365.us`*), and you connect with* `Connect-ExchangeOnline -ExchangeEnvironmentName O365USGovGCCHigh` *(or* `O365USGovDoD`*). The SPF include and DKIM CNAME targets follow the sovereign cloud's values —* ***verify the exact include host and CNAME targets in your tenant/cloud*** *rather than assuming the Commercial* `spf.protection.outlook.com` */* `onmicrosoft.com` *values.*

Global Requirements — Microsoft 365 / Exchange Messaging Solutions

These requirements apply to **every** solution in the **Messaging** category (Exchange Online & Exchange hybrid mail flow, connectors, mail hygiene, email authentication, federation, archiving, client connectivity, and messaging support operations). They are the common foundation each solution assumes is already in place (or stands up as part of its own Requirements section). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Messaging solution).*** *The* ***Exchange admin center (EAC)****, the* ***Microsoft 365 admin center****,* ***Exchange Online PowerShell (EXO V3 module)****,* ***Microsoft Graph****, and on-premises* ***Exchange Server / Active Directory*** *are authored at exact, current click-by-click and cmdlet detail from Microsoft's public documentation. Where a capability, default, or portal path is* ***version- or plan-dependent*** *(Exchange Server build/CU, EOP vs Defender for Office 365 plan, Exchange Online Archiving / auto-expanding archive availability, Commercial vs Government cloud), it is* ***cited or flagged "verify in your tenant/version"*** *— never invented.* ***Third-party mail hygiene, archiving, and signature/gateway products*** *are integrated at the pattern level; their internal consoles are deferred to the vendor's own docs.* ***Commercial vs Government (GCC/GCC High/DoD)*** *portal URLs and endpoints differ — where a solution's setup materially differs on a sovereign cloud, flag it (per the house Commercial-vs-Government rule). Automation is delivered as* ***PowerShell*** *(Exchange Online PowerShell / Graph) — never with hardcoded credentials or secrets in code.*

1. Microsoft 365 tenant with Exchange Online

• **Description:** A Microsoft 365 tenant with **Exchange Online** and the appropriate licensing for the

capability in scope (e.g. Exchange Online Plan 1/2, EOP, **Defender for Office 365** for advanced hygiene, Exchange Online Archiving / auto-expanding archive where required).

• **Why required:** All mail-flow, hygiene, archiving, and client configuration is performed against this tenant and depends on the right plan.

• **How to verify:** Sign in to the Microsoft 365 admin center; confirm the Exchange Online subscription and license counts under **Billing > Licenses**.

• **How to implement if missing:** Provision/assign the required licensing before starting.

2. Administrative access (least-privilege Exchange/365 roles)

• **Description:** Administrative access with the **least-privilege role** the solution names — typically **Exchange Administrator** (or specific EAC role groups such as Organization Management, Recipient/Records/Hygiene Management), and **Global Administrator** only where genuinely required (e.g. federation/ADFS, connector auth).

• **Why required:** Mail-flow, connector, hygiene, archiving, and federation changes require the corresponding admin role.

• **How to verify:** Confirm the role assignment in the Microsoft 365 admin center / Entra roles.

• **How to implement if missing:** Have a Global Admin assign the least-privilege role under change control.

3. Exchange Online PowerShell (EXO V3) + Graph toolchain

• **Description:** A workstation with the **ExchangeOnlineManagement (EXO V3)** PowerShell module and, where used, **Microsoft Graph PowerShell**; modern-auth / MFA-capable admin sign-in.

• **Why required:** Configuration, automation, and the provided scripts run through EXO PowerShell / Graph; Basic Auth is retired.

• **How to verify:** `Connect-ExchangeOnline` succeeds with the admin account; `Get-Module ExchangeOnlineManagement`.

• **How to implement if missing:** Install the module (`Install-Module ExchangeOnlineManagement`) and confirm modern-auth sign-in before running the steps.

4. DNS control for the mail domains

• **Description:** Ability to create/modify **DNS records** (MX, SPF (TXT), DKIM (CNAME), DMARC (TXT), Autodiscover, and connector/host records) for the domains in scope.

• **Why required:** Email authentication, mail routing/coexistence, connector validation, and client autodiscover all depend on DNS.

• **How to verify:** Confirm access to the authoritative DNS zone for each mail domain.

• **How to implement if missing:** Coordinate with whoever controls DNS; stage changes under change control (mail-flow and authentication changes are high-impact).

5. Hybrid Exchange & Active Directory (for hybrid solutions)

• **Description:** For **hybrid / on-premises** solutions, access to the on-premises **Exchange Server** organization (correct roles/CU), **Active Directory**, **Azure AD Connect** (directory sync), and the relevant network/firewall paths (e.g. for Edge/transport, hybrid connectors, autodiscover).

• **Why required:** Hybrid mail flow, Edge Transport, connectors, and federation read from and change the on-premises side.

• **How to verify:** Confirm on-prem Exchange admin access, AD access, and that directory sync is healthy.

• **How to implement if missing:** Obtain access and confirm the on-prem Exchange/AD/AAD-Connect health

before making hybrid changes.

6. A pilot scope and change control

• **Description:** A **pilot group / accepted-domain / test mail flow** to validate on before fleet-wide rollout, and a **change-control** process for production changes (mail flow, connectors, DNS, authentication, hygiene policy are all high-impact).

• **Why required:** Every solution follows an **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand**

model; the pilot proves the design and change control protects production mail flow.

• **How to verify:** Confirm a named pilot scope and an approval/change window are available.

• **How to implement if missing:** Define a pilot scope and agree change control with the messaging/ service owners before making production changes.

*The deployment model across every Messaging solution is the same: **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand**, with explicit pass/fail gates and a documented rollback for production changes. Automation is delivered as **PowerShell** (Exchange Online PowerShell / Graph) — never with hardcoded credentials or secrets in code.*

Implementation

Follow these steps in order. They realize the house model — **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand** — pilot-first, with explicit pass/fail gates and a rollback at each DNS/auth change. Every artifact is **named** with the convention `<Purpose> – <Scope> – <Stage>` and that exact name is reused in testing, troubleshooting, and the scripts.

> ***High-impact warning.*** *SPF, DKIM, and DMARC are DNS/authentication changes that affect* ***production mail deliverability****. A mis-scoped SPF record, an incorrect DKIM CNAME, or a premature* `p=reject` *can cause legitimate mail to be filtered or rejected. Lower DNS TTLs first, change one record at a time, and never advance a gate on assumption — advance it on aggregate-report evidence.*

Artifacts produced (named once, reused throughout):

Artifact	Name
SPF record	`SPF Record – <domain> – Prod`
DKIM signing config	`DKIM Signing – <domain> – Prod`
DKIM CNAMEs	`DKIM CNAME selector1/2 – <domain> – Prod`
DMARC monitor record	`DMARC Policy – <domain> – Monitor`
DMARC quarantine record	`DMARC Policy – <domain> – Quarantine`
DMARC enforce record	`DMARC Policy – <domain> – Reject`
Report mailbox	`DMARC RUA – <domain> – Prod`
Sender inventory	`Sender Inventory – <domain> – Baseline`

Phase 1 — Assess (inventory & baseline)

Step 1.1 — Connect and confirm scope

1. On the admin workstation, connect: `Connect-ExchangeOnline` (GCC High: add

`-ExchangeEnvironmentName O365USGovGCCHigh`). For DKIM CNAME targets you may also use Graph: `Connect-MgGraph -Scopes "Domain.Read.All"`.

1. List accepted domains: `Get-AcceptedDomain | Select-Object DomainName,DomainType,Default`. Record the

in-scope domains and the tenant **initial domain** (`<tenant>.onmicrosoft.com`).

Step 1.2 — Baseline current authentication posture (read-only)

1. Run the discovery script `Get-EmailAuthPosture.ps1` against all accepted domains. It reports, per

domain: the current SPF `TXT` (and whether it exceeds 10 lookups / uses `~all` vs `-all`), the DKIM signing config state and whether the CNAMEs resolve, and the DMARC record/policy (if any). Save the output as the baseline for `Sender Inventory – <domain> – Baseline`.

1. From the M365 admin center and message trace, enumerate senders and reconcile against R1's inventory.

Gate 1 (Assess): A per-domain baseline exists and the sender inventory has **no known gaps** in the categories of R1 (EXO, on-prem/hybrid, third-party). Unknowns are acceptable here — they will be closed in Phase 4 from the reports — but every *known* system must be listed. Rollback: none (read-only).

Phase 2 — Design

Step 2.1 — Design the SPF record (`SPF Record – <domain> – Prod`)

1. Compose a **single** SPF `TXT` record per domain, in this order: `v=spf1`, then each authorized

source, then the all-qualifier. For Exchange Online include `include:spf.protection.outlook.com`. Add each third-party sender's published `include:` (from R5) and any static on-prem egress IPs as `ip4:`/`ip6:`.

1. **Stay under the 10-DNS-lookup limit** (`include`, `a`, `mx`, `ptr`, `exists` each count). Count the

nested lookups (the discovery/scope script estimates this). If over 10, consolidate: drop unused `include:`, replace an `include:` with the vendor's published `ip4:` ranges where they document them, or move a noisy sender to a sending **subdomain** with its own SPF.

1. Choose the final qualifier: publish with `~all` (soft fail) during pilot, tightening to `-all` (hard

fail) once the inventory is proven complete. Never publish more than one `v=spf1` record per domain.

Step 2.2 — Design the DKIM rollout (`DKIM Signing – <domain> – Prod`)

1. Retrieve the exact CNAME targets: `Get-DkimSigningConfig -Identity <domain> | fl *CNAME*` (this

returns `Selector1CNAME` / `Selector2CNAME`, e.g. `selector1-<domainGUID>._domainkey.<tenant>.onmicrosoft.com`). These become `DKIM CNAME selector1/2 – <domain> – Prod`.

1. For each third-party sender that will DKIM-sign as your domain (R5), note the vendor selector/CNAME to

publish.

Step 2.3 — Design the DMARC rollout

1. Provision/confirm the RUA mailbox `DMARC RUA – <domain> – Prod` (e.g. `dmarc-reports@<domain>`).
2. Plan the three DMARC records (monitor → quarantine → reject) and the `pct=` ramp for the enforcement

step. Decide `sp=` (subdomain policy) and `adkim`/`aspf` alignment mode (default relaxed `r`).

Gate 2 (Design): A written SPF string (≤10 lookups), the two DKIM CNAME targets, the RUA destination, and the three planned DMARC records are all documented and reviewed under change control.

Phase 3 — Configure (publish SPF & DKIM, DMARC at monitor)

Step 3.1 — Publish/scope SPF (`SPF Record – <domain> – Prod`)

1. In the domain's DNS zone, create/replace the single SPF `TXT` record with the string from Step 2.1,

using `~all` for now. Remove any duplicate/legacy `v=spf1` records.

1. Verify: `Resolve-DnsName -Type TXT <domain>` shows exactly one `v=spf1` record; the scope helper

confirms lookups ≤ 10. **Rollback:** restore the previous TXT value (kept from Gate-1 baseline).

Step 3.2 — Enable Exchange Online DKIM (`DKIM Signing – <domain> – Prod`)

1. Publish the two CNAMEs from Step 2.2 in DNS: `selector1._domainkey.<domain>` and

`selector2._domainkey.<domain>` → the `Selector1CNAME`/`Selector2CNAME` targets. Wait for DNS propagation.

1. Enable signing — safe to dry-run first with the config script's `-WhatIf`, then apply:

`Set-DkimSigningConfig -Identity <domain> -Enabled $true`. If the config object doesn't exist yet, create it: `New-DkimSigningConfig -DomainName <domain> -Enabled $true` (this generates the CNAME targets to publish, then re-run enable after DNS is live).

1. Verify: `Get-DkimSigningConfig -Identity <domain>` shows `Enabled : True` and `Status : Valid` and no

"CNAME not found" error. Send a test message to an external mailbox and confirm the header shows `dkim=pass header.d=<domain>`. **Rollback:** `Set-DkimSigningConfig -Identity <domain> -Enabled $false` (Exchange Online falls back to signing with the `onmicrosoft.com` domain).

1. **Rotation:** to rotate keys on schedule or after a suspected compromise, run

`Rotate-DkimSigningConfig -Identity <domain>` (this moves signing to the alternate selector and generates fresh 2048-bit keys behind the CNAMEs). The config script includes a guarded `-Rotate` path.

Step 3.3 — Align on-prem/hybrid & third-party senders

1. **On-prem/hybrid:** if on-prem-origin mail egresses via Exchange Online, it is already SPF/DKIM

covered. If it egresses **directly** to the internet, add its public IP(s) to the SPF record and, if possible, route it through Exchange Online (or a subdomain) so it can be DKIM-aligned; otherwise it will rely on aligned SPF only.

1. **Third-party:** for each platform (R5), enable domain authentication in the vendor console and

publish the CNAME/TXT they provide so they sign with `d=<domain>` and/or add their `include:` to SPF.

Step 3.4 — Publish DMARC at monitor (`DMARC Policy – <domain> – Monitor`)

1. Create the `_dmarc.<domain>` `TXT` record:

`v=DMARC1; p=none; rua=mailto:dmarc-reports@<domain>; fo=1; adkim=r; aspf=r`. (Add `sp=none` explicitly if the subdomain policy should differ.)

1. Verify: `Resolve-DnsName -Type TXT _dmarc.<domain>` returns exactly one `v=DMARC1` record.

Rollback: delete the `_dmarc` record (returns the domain to no-DMARC).

Gate 3 (Configure): SPF resolves as one record ≤10 lookups; DKIM `Status : Valid` and a test message shows `dkim=pass`; the DMARC monitor record resolves and reports begin arriving at the RUA mailbox.

Phase 4 — Pilot (monitor with aggregate reports)

1. Let `DMARC Policy – <domain> – Monitor` (`p=none`) run and collect **aggregate reports** for a

representative window (typically **2–4 weeks**, long enough to capture monthly/low-frequency senders like billing).

1. Parse the reports with `Invoke-DmarcReportAnalysis.ps1`: it aggregates by source IP/organization and

reports, per source, message volume and whether it **passes DMARC with alignment** (SPF-aligned, DKIM-aligned, or failing). Reconcile every source against `Sender Inventory – <domain> – Baseline`.

1. For each source that is **failing DMARC**: identify it, decide if it is legitimate, and remediate

(add to SPF, enable the vendor's DKIM, or move it behind Exchange Online / a subdomain). Repeat until the reports show **all legitimate mail passing and aligned** and any remaining failures are known illegitimate/spoof traffic.

Gate 4 (Pilot) — the enforcement gate: The aggregate reports show **100% of legitimate senders passing DMARC with alignment**, with **no unknown legitimate sources** still failing. Do **not** advance to quarantine/reject until this holds. Rollback: none needed (`p=none` takes no action on mail).

Phase 5 — Validate

1. Run `Test-EmailAuthAlignment.ps1` to produce the alignment validation report: SPF resolves ≤10

lookups and covers all inventoried senders; DKIM `Status : Valid` with resolving CNAMEs and a passing test signature; DMARC record present; and the report-derived source list has zero unaligned legitimate senders.

1. Confirm with an external check (send to an external provider and read the Authentication-Results

header: `spf=pass`, `dkim=pass header.d=<domain>`, `dmarc=pass`).

Gate 5 (Validate): The validation report is green on all four checks (SPF scoped, DKIM valid, DMARC present, all legit senders aligned). This is the go/no-go for enforcement.

Phase 6 — Expand (roll DMARC to enforcement)

1. **Tighten SPF** to `-all` (hard fail) now that the inventory is proven complete (`SPF Record –

<domain> – Prod`). Verify and watch the next report cycle.

1. **Quarantine (**`DMARC Policy – <domain> – Quarantine`**):** update `_dmarc.<domain>` to

`p=quarantine; pct=25;` … then ramp `pct=` 25 → 50 → 100 across report cycles, watching for any new legitimate failures. Keep `rua=` unchanged. **Rollback:** revert to `p=none` (or lower `pct=`).

1. **Reject (**`DMARC Policy – <domain> – Reject`**):** once quarantine at `pct=100` is clean, update to

`p=reject; pct=100; rua=mailto:dmarc-reports@<domain>`. **Rollback:** revert to `p=quarantine`.

1. **Steady state:** keep `Invoke-DmarcReportAnalysis` running on a schedule; new sources or spoof spikes

surface in the reports. Rotate DKIM per policy with `Rotate-DkimSigningConfig`.

Gate 6 (Expand): `_dmarc.<domain>` is at `p=reject; pct=100`, reports remain clean (no legitimate mail rejected), and ongoing monitoring is scheduled. Full rollback path at any step: step the policy back one stage (reject → quarantine → none) — the record change is immediate and reversible.

Testing & Validation

Run these tests at the gates called out in the Implementation guide. Each has an explicit **pass/fail**. Do not advance a DMARC stage on a failed test.

T1. SPF resolves as a single, scoped record

- **How:** `Resolve-DnsName -Type TXT <domain>` (or run `Get-EmailAuthPosture.ps1`).
- **Pass:** Exactly **one** `v=spf1` record; it includes `spf.protection.outlook.com` plus every

inventoried sender; the estimated DNS lookup count is ≤ **10**; qualifier is `~all` (pilot) or `-all` (enforced).

- **Fail:** Two or more `v=spf1` records, missing a legitimate sender, `> 10` lookups (would `permerror`),

or an unintended `+all`. → Fix per Implementation Step 3.1 / 2.1 before proceeding.

T2. DKIM signing is enabled and valid

- **How:** `Get-DkimSigningConfig -Identity <domain> | fl Enabled,Status,Selector1CNAME,Selector2CNAME`;

and `Resolve-DnsName -Type CNAME selector1._domainkey.<domain>`.

- **Pass:** `Enabled : True`, `Status : Valid`; both `selector1._domainkey` and `selector2._domainkey`

CNAMEs resolve to the Microsoft-hosted targets.

- **Fail:** `Status` shows a CNAME-not-found error, or a selector doesn't resolve. → Republish the exact

CNAME targets (Step 3.2) and wait for propagation.

T3. A test message passes SPF and DKIM (and aligns)

- **How:** Send from an Exchange Online mailbox on `<domain>` to an external mailbox at a DMARC-honoring

provider; open the raw message and read `Authentication-Results`.

- **Pass:** `spf=pass` for an aligned MAIL FROM, `dkim=pass header.d=<domain>` (note `d=` equals your

custom domain, **not** `onmicrosoft.com`), and — once DMARC is published — `dmarc=pass`.

- **Fail:** `dkim=pass header.d=<tenant>.onmicrosoft.com` (DKIM not aligned — custom-domain DKIM not

enabled), `spf=softfail/fail`, or `dmarc=fail`. → Enable custom-domain DKIM (Step 3.2) / fix SPF.

T4. DMARC record is published and reports arrive

- **How:** `Resolve-DnsName -Type TXT _dmarc.<domain>`; check the `DMARC RUA – <domain> – Prod` mailbox.
- **Pass:** Exactly one `v=DMARC1` record with the intended `p=` and a valid `rua=`; aggregate report XML

arrives at the RUA mailbox within 24–72h of publishing.

- **Fail:** No record, malformed tags, wrong/absent `rua=`, or no reports after 72h (check the mailbox

and, for cross-domain reporting, the external-destination verification TXT). → Fix per Step 3.4 / R6.

T5. All legitimate senders pass DMARC with alignment (enforcement gate)

- **How:** Run `Invoke-DmarcReportAnalysis.ps1` over the collected reports and reconcile against

`Sender Inventory – <domain> – Baseline`.

- **Pass:** Every legitimate source in the inventory shows **DMARC pass with SPF- or DKIM-alignment**;

the only failing sources are known-illegitimate/spoof traffic; **no unknown legitimate source** is failing.

- **Fail:** Any legitimate/unknown source is failing DMARC. → Remediate that source (SPF/DKIM/subdomain)

and re-collect before advancing. **This is the gate that blocks** `p=quarantine`**/**`p=reject`**.**

T6. Alignment validation report is green

- **How:** Run `Test-EmailAuthAlignment.ps1`.
- **Pass:** All four checks green — SPF scoped (≤10 lookups, all senders covered), DKIM valid, DMARC

present, zero unaligned legitimate senders.

- **Fail:** Any check red. → Address the specific failure before enforcement.

T7. Enforcement takes effect without dropping legitimate mail

- **How:** After moving to `p=quarantine` (ramping `pct=`) and then `p=reject`, keep running

`Invoke-DmarcReportAnalysis.ps1` each report cycle; send legitimate test mail through each real sender.

- **Pass:** Spoofed/forged `From:<domain>` mail is quarantined/rejected by receivers; **all legitimate

senders continue to be delivered** and show `dmarc=pass`.

- **Fail:** A legitimate sender's mail is quarantined/rejected. → Immediately step the policy back one

stage (reject → quarantine → none), remediate the sender, then re-ramp.

T8. DKIM rotation succeeds

- **How:** Run `Rotate-DkimSigningConfig -Identity <domain>`; re-test T2/T3.
- **Pass:** Signing continues (`Status : Valid`), new selector active, test message still `dkim=pass header.d=<domain>`.
- **Fail:** DKIM breaks after rotation (usually a selector CNAME not resolving). → Confirm both selector CNAMEs are published; Exchange Online rotates between the two published selectors.

Troubleshooting

Common failure modes when implementing SPF, DKIM, and DMARC on Microsoft 365, with resolutions. Symptoms are what you observe in `Authentication-Results` headers, aggregate reports, or the provided scripts.

SPF

SPF `permerror` / "too many DNS lookups"

- **Symptom:** `spf=permerror`; mail intermittently junked; `Get-SpfLookupHealth.ps1` reports > 10.
- **Cause:** The record's `include:`/a/mx/ptr/`exists` mechanisms exceed the RFC 7208 **10-lookup** limit — usually stacked third-party `include:` chains.
- **Resolution:** Consolidate `SPF Record – <domain> – Prod`: drop unused includes, replace an `include:` with the vendor's published `ip4:` ranges, or move a noisy sender to a sending subdomain with its own SPF. Re-run `Get-SpfLookupHealth.ps1` until ≤ 10.

Two SPF records / `permerror`

- **Symptom:** `Get-EmailAuthPosture.ps1` shows `SpfRecordCount = 2`.
- **Cause:** More than one `v=spf1` TXT record — invalid.
- **Resolution:** Merge into a single record; delete the extras.

Legitimate sender soft/hard-failing SPF

- **Symptom:** A known sender shows `spf=fail`/`softfail` in reports.
- **Cause:** Its sending host/IP or vendor `include:` is missing from the record.
- **Resolution:** Add the vendor's published `include:` or the on-prem egress `ip4:` to `SPF Record – <domain> – Prod`; keep `~all` until verified, then `-all`.

DKIM

DKIM enable fails — "CNAME record does not exist"

- **Symptom:** `Get-DkimSigningConfig` shows a CNAME-not-found error; `Status` not `Valid`.
- **Cause:** The two selector CNAMEs aren't published, are mistyped, or haven't propagated. The targets must match `Selector1CNAME`/`Selector2CNAME` exactly (derived from the tenant initial domain + Domain GUID).
- **Resolution:** Publish `DKIM CNAME selector1/2 – <domain> – Prod` exactly as `Set-DkimSigning.ps1 -WhatIf` prints them; wait for propagation; re-run enable. Verify with `Resolve-DnsName -Type CNAME selector1._domainkey.<domain>`.

DKIM passes but with `d=<tenant>.onmicrosoft.com` (not aligned)

- **Symptom:** `dkim=pass header.d=<tenant>.onmicrosoft.com`; DMARC still fails DKIM alignment.
- **Cause:** Custom-domain DKIM isn't enabled, so Exchange Online signs with the initial domain, which doesn't align to your custom `From:`.
- **Resolution:** Enable custom-domain DKIM (`Set-DkimSigning.ps1 -Domain <domain> -Commit`) so signing uses `d=<yourdomain>`.

DKIM breaks after rotation

- **Symptom:** `dkim=fail` right after `Rotate-DkimSigningConfig`.
- **Cause:** The alternate selector's CNAME isn't published/resolving.
- **Resolution:** Ensure **both** `selector1` and `selector2` CNAMEs are published — Exchange Online rotates between the two. Re-test with T2/T3.

DMARC

No aggregate reports arriving

- **Symptom:** `DMARC RUA – <domain> – Prod` mailbox stays empty > 72h after publishing `p=none`.
- **Cause:** Missing/incorrect `rua=`; the `_dmarc` record didn't publish; or cross-domain reporting lacks the external-destination verification TXT.
- **Resolution:** Confirm `_dmarc.<domain>` resolves with a valid `rua=mailto:` (T4). For a report address on a different domain, publish `<yourdomain>._report._dmarc.<reportdomain>` TXT = `v=DMARC1`.

Legitimate mail quarantined/rejected after tightening policy

- **Symptom:** A real sender's mail is junked/bounced after moving to `p=quarantine`/`p=reject`.
- **Cause:** That source wasn't aligned (missing SPF entry or vendor DKIM) and enforcement was advanced

before the reports were clean — the enforcement gate (T5) was not met.

- **Resolution: Immediately step the policy back one stage** (`DMARC Policy – <domain> – Reject` →

`Quarantine` → `Monitor`). Remediate the source (add to SPF, enable vendor DKIM as `d=<domain>`, or route via Exchange Online/a subdomain), confirm it passes in the reports, then re-ramp `pct=`.

DMARC fails only for forwarded mail

- **Symptom:** Reports show DMARC failures from mailing lists / forwarders.
- **Cause:** Forwarding changes the connecting IP (breaks SPF alignment) and may alter the body (breaks

DKIM).

- **Resolution:** Rely on **DKIM alignment**, which usually survives forwarding; ensure custom-domain

DKIM is enabled. Treat residual forwarder failures as expected noise, not a legitimate-sender break.

Subdomain spoofing still getting through at `p=reject`

- **Symptom:** Spoofed mail from `x.<domain>` isn't rejected though the org domain is at `p=reject`.
- **Cause:** No policy applies to the subdomain; without `sp=`, the subdomain inherits the org policy

only if it has no record of its own — verify behavior.

- **Resolution:** Set an explicit subdomain policy (`sp=reject`) on the org `_dmarc` record, or publish a

DMARC record on the subdomain.

Environment / cloud

Cmdlets or portals not found in Government cloud

- **Symptom:** `Connect-ExchangeOnline` connects to the wrong endpoint; CNAME targets or portal URLs

don't match.

- **Cause:** GCC High / DoD uses different endpoints and the `*.onmicrosoft.us` initial domain.
- **Resolution:** Connect with `-ExchangeEnvironmentName O365USGovGCCHigh` (or `O365USGovDoD`); use

`admin.exchange.office365.us`; and **verify the SPF include host and DKIM CNAME targets for your cloud** rather than assuming Commercial values.

`Connect-ExchangeOnline` *fails / module missing*

- **Symptom:** Command not recognized, or auth errors.
- **Cause:** ExchangeOnlineManagement (EXO V3) not installed, or Basic Auth expected.
- **Resolution:** `Install-Module ExchangeOnlineManagement`; connect with modern auth/MFA (per global

requirement GR-3). No stored credentials — the scripts never embed secrets.

Best Practices

Durable practices for keeping a Microsoft 365 domain authenticated, aligned, and safely enforced.

Sequence and evidence

- **Never enforce before you monitor.** Always publish DMARC at `p=none` first and let aggregate reports run for 2–4 weeks. Enforcement decisions must be driven by report data, not assumptions.
- **Ramp, don't leap.** Move `p=none` → `p=quarantine` → `p=reject`, and use `pct=` (25 → 50 → 100) within the quarantine/reject step so a missed sender is caught on a fraction of mail, not all of it.
- **Treat "unknown source in reports" as a hard gate.** An unidentified source that turns out to be legitimate will break at enforcement — resolve every unknown before tightening policy.

SPF hygiene

- **One SPF record per domain.** Multiple `v=spf1` TXT records is a `permerror`; merge into one.
- **Stay under 10 DNS lookups.** Audit `include:`/a/mx/ptr/`exists` regularly, especially after adding a vendor. Consolidate by using vendors' published `ip4:` ranges or a sending subdomain instead of stacking nested `include:` chains.
- **End with `-all` once proven.** Use `~all` during pilot, tighten to `-all` after the inventory is complete. `+all` is never correct.
- **Don't rely on SPF alone for DMARC** — forwarding breaks SPF alignment. Ensure DKIM alignment is present so DMARC survives forwarding.

DKIM hygiene

- **Enable custom-domain DKIM on every accepted domain** you send from — the default `onmicrosoft.com` signature does **not** align to your custom `From:` domain.
- **Publish both selector CNAMEs** and keep them in place; Exchange Online rotates between selector1 and selector2. Rotate keys periodically with `Rotate-DkimSigningConfig`, and immediately if a key is suspected compromised.
- **Extend DKIM alignment to third-party senders** — have each platform sign with `d=<yourdomain>` (publish the vendor's CNAMEs) rather than relying only on adding them to SPF.

DMARC hygiene

• **Keep** `rua=` **on permanently**, even after reaching `p=reject` — reports are your early-warning system for new shadow senders, vendor changes, and spoof campaigns.

• **Set a subdomain policy (**`sp=`**)** deliberately; unused subdomains are a common spoofing target — an organizational `p=reject` with `sp=reject` closes them.

• **Use relaxed alignment (**`adkim=r`**,** `aspf=r`**) by default**; only move to strict (`s`) if you have a specific reason and have confirmed all senders align strictly.

• **Consider** `_dmarc` **on a parent org domain** to cover subdomains, plus a policy record for the org domain itself.

Operations

• **Lower DNS TTLs** (e.g. 300–3600s) before a rollout so staged changes and rollbacks propagate fast.

• **Change one record at a time under change control**, keeping the prior value for instant rollback.

• **Schedule the report analysis** so drift (a new un-aligned sender) is caught within a cycle, not at the next incident.

• **Layer DMARC with anti-phishing.** DMARC stops exact-domain spoofing only; pair it with Defender for Office 365 anti-phish / spoof intelligence for display-name and look-alike-domain protection (plan-dependent — verify your EOP vs Defender for Office 365 plan).

• **Document the final records** (SPF string, DKIM selectors, DMARC policy, RUA destination) and the sender inventory as living operational documentation.

Government / sovereign cloud

• In **GCC High / DoD**, verify the exact SPF include host, DKIM CNAME targets (`*.onmicrosoft.us`), and portal URLs (`*.office365.us`) for your cloud — don't assume Commercial values. Connect with the matching `-ExchangeEnvironmentName`.

Deliverables Summary

This solution delivers a complete, self-guided package to implement SPF, DKIM, and DMARC on a Microsoft 365 domain — and reach DMARC enforcement (`p=reject`) without breaking legitimate mail.

Documentation

• **Solution Overview** — SPF/DKIM/DMARC and alignment, the Exchange Online DKIM model (CNAMEs + rotation), third-party sender handling, and the monitor→enforce journey.

• **Requirements Guide** — the solution-specific prerequisites (sender inventory, accepted/verified

domains, tenant initial domain & Domain GUID, DNS TXT/CNAME support, third-party alignment methods, RUA destination, Exchange Administrator role), each with how to *verify* and *implement*, referencing the shared messaging global requirements.

- **Implementation Guide** — exact ordered steps across Assess → Design → Configure → Pilot → Validate →

Expand, with every artifact named, pass/fail gates, and a rollback at each DNS/auth change.

- **Testing & Validation** — eight tests (T1–T8), each with an explicit pass/fail, including the

enforcement gate.

- **Troubleshooting** — common failure modes (SPF >10 lookups, DKIM CNAME/`onmicrosoft` alignment,

DMARC failures, forwarding, no reports, GCC High differences) with resolutions.

- **Best Practices** — durable guidance for reaching and holding `p=reject` safely.
- **Executive Summary** — outcome, approach, and why the rollout is low-risk.

PowerShell scripts (Exchange Online PowerShell / Microsoft Graph)

All are **read-only or `-WhatIf`/`-Commit`-gated by default**, use modern auth (`Connect-ExchangeOnline`), and contain **no hardcoded credentials or secrets**.

1. `Get-EmailAuthPosture.ps1` — *Discovery (read-only).* Baselines SPF (record count, lookup

estimate, all-qualifier), DKIM (enabled/status, CNAME resolution), and DMARC (policy, RUA) across all accepted domains.

1. `Set-DkimSigning.ps1` — *Configuration/Remediation (safe by default).* Shows the exact Selector1/2

CNAME targets and, only with `-Commit`, enables DKIM (`Set-DkimSigningConfig -Enabled $true`) or, with `-Rotate`, rotates keys (`Rotate-DkimSigningConfig`). Supports `-WhatIf`.

1. `Invoke-DmarcReportAnalysis.ps1` — *Reporting (read-only).* Parses DMARC aggregate (RUA) report

XML and rolls up by source IP with SPF/DKIM alignment and DMARC pass %; `-FailingOnly` surfaces the enforcement-blocking sources.

1. `Test-EmailAuthAlignment.ps1` — *Validation (read-only).* Emits a green/red report per domain:

SPF scoped (≤10 lookups), DKIM Valid with resolving CNAMEs, DMARC present — the enforcement go/no-go.

1. `Get-SpfLookupHealth.ps1` — *Scope/health helper (read-only).* Recursively resolves the SPF

record, counts real DNS lookups against the 10-lookup limit, and prints the include tree so you can see which sender consumes the budget.

Packaged artifacts

- `M365AUTH-Solution.pdf` — the compiled solution document (all sections above).

- `M365AUTH-Scripts.zip` — the five PowerShell scripts.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

Get-EmailAuthPosture.ps1

Get-SpfLookupHealth.ps1

Invoke-DmarcReportAnalysis.ps1

Set-DkimSigning.ps1

Test-EmailAuthAlignment.ps1